

Sri Lanka Institute of Information Technology



Web Security

Bug Bounty Report Introduction

Year 2, Semester 2

Sirisena D A

IT23330832

Web Security - IE2062

B.Sc. (Hons) in Information Technology Specializing in Cyber Security

What is a Bug Bounty?

A bug bounty is a program offered by organizations, websites, and software developers to incentivize individuals—often referred to as bug bounty hunters, ethical hackers, or white hats—to identify and report security vulnerabilities or bugs in their systems. These programs provide rewards, which can include monetary compensation, recognition, or other incentives, in exchange for responsibly disclosing flaws before they can be exploited by malicious actors. Unlike traditional penetration testing, which is conducted by hired professionals, bug bounties leverage a crowdsourced approach, tapping into a global community of security researchers to enhance cybersecurity.

Importance of Bug Bounty Programs

Bug bounties play a critical role in improving software security by:

- **Proactively Identifying Vulnerabilities:** They help uncover zero-day vulnerabilities—flaws unknown to the vendor—before they can be exploited.
- **Cost-Effectiveness:** Paying bounties for discovered bugs is often cheaper than the cost of a data breach or hiring full-time security teams.
- **Continuous Security Testing:** Unlike one-time audits, bug bounties provide ongoing protection as hunters continuously test systems.
- **Public Relations Benefit:** Companies that run bug bounties demonstrate a commitment to security, boosting trust with users and regulators.
- **Talent Access:** Organizations gain access to a diverse pool of skilled hackers who might not otherwise be available for hire.

Key Details

Types of Programs

- **Public Programs:** Open to anyone (e.g., Google, Facebook), allowing broad participation but increasing competition.
- **Private Programs:** Invitation-only, targeting specific researchers for confidentiality or specialized testing.
- **Vulnerability Disclosure Programs (VDPs):** Focus on responsible disclosure without guaranteed financial rewards, often used by smaller organizations.

How It Works

1. **Scope Definition:** Companies specify which assets (e.g., websites, apps) are in scope and the rules for testing.

2. **Hunting:** Ethical hackers use their skills to find vulnerabilities like XSS, SQL injection, or CSRF.
3. **Reporting:** Hunters submit detailed reports, including steps to reproduce the issue and its impact.
4. **Validation:** The organization verifies the bug and assesses its severity.
5. **Reward:** If valid, the hunter receives a bounty based on severity (e.g., low: \$50, critical: \$10,000+), with payouts varying by company size and program.
6. **Fixing:** The organization patches the vulnerability and may credit the hunter.

Considerations

- **Eligibility:** Rewards are typically for new, valid findings; duplicates or known issues are ineligible.
- **Ethical Responsibility:** Hunters must follow disclosure policies and avoid causing harm.
- **Challenges:** Programs may face invalid reports (50-70% in some cases) or attract malicious actors, requiring robust management.

Getting Started

- **Skills Needed:** Basic knowledge of web technologies (HTML, JavaScript, HTTP), networking, and common vulnerabilities.
- **Resources:** Practice on vulnerable apps (e.g., DVWA, WebGoat) or start with VDPs to build reputation.
- **Platforms:** Use sites like HackerOne, Bugcrowd, or Intigriti to find programs.

Vulnerability Testing Tools

Tool	Use
------	-----

Burp Suite	Intercept HTTP traffic, modify requests, fuzzing
-------------------	--

ZAP	Automated scanning and spidering
------------	----------------------------------

SQLMap	Automated SQLi detection & exploitation
---------------	---

Bug bounties empower both organizations and individuals, fostering a collaborative approach to securing the digital world while offering rewarding opportunities for ethical hackers.

ZAP

ZAP or Zed Attack Proxy is a top-tier open-source tool for web application security testing. Developed by OWASP it offers a user-friendly interface and strong functionality for both manual and automated testing. With proxy capabilities it intercepts HTTP/HTTPS traffic aiding in vulnerability detection. ZAP's scanning techniques include active and passive methods finding typical vulnerabilities like SQL injection and XSS. It also includes spidering fuzzing, and script automation. Customizable alarms and thorough reporting streamline vulnerability management. Trusted globally ZAP's regular updates ensure it stays effective against changing threats helping enterprises to protect their online applications easily.

ZAP Automated scan Domain

